Activity 4 Report: Database Users, Roles, Privileges and Access Control

COMP 018 Database Administration | Project tested: Park It (Parking Management System) (PHP + PostgreSQL) | Date of testing: 7 November 2026

1. Cover and links

Item	Value
Testing group	G08: Borreta, Joshua; Bola, Martin Lawrence; Juatchon, Joaquin Phillip; Marcos, Karl Raphael; Pacheco Jr., Sancho; Vera Cruz, Euan Joseph
Project tested	Park It (Parking Management System)
Owning group	Group 2 (member names are not listed in the project files)
Repository	park-it-database (project zip park-it-database-main; the repository link is not included in the files we received)
Tracker	https://github.com/EclipseChan/bwisIT-Solutions---Campus-Canteen-Pre-Order-and-Queue-Management-System/tree/main/other_group_tests
Evidence files	a4_access_tests.txt, a4_app_roles.txt, a3_deploy.txt, a3_app.txt

Every result below comes from this run on a freshly created database.

2. Access-control plan (from the project docs)

user-role.md describes two application roles, Administrator (admin) and Staff, and one system account for the PHP app. Administrator registers vehicles; Staff searches active vehicles, takes payments and exits vehicles. In the database it proposes a group role parkit_runtime_grp (NOLOGIN) and a login account parkit_app that is a member of it, with SELECT, INSERT and UPDATE on the tables the app needs and no DELETE. The document says the role checks must be done in PHP on every protected action, and that the app should not run as postgres. There is no SQL file for the roles; the SQL is inside the document (sections 4.1 to 4.3).

3. The document's SQL, run as written

The SQL from sections 4.1 to 4.3 was copied out unchanged (only the sample password was replaced) and run on the new database, then run a second time.

Check	Result
First run	Both roles created, 5 GRANT statements ran, membership granted. No errors
Second run	Errors: role parkit_runtime_grp and parkit_app already exist (CREATE ROLE has no IF NOT EXISTS). The grants repeat harmlessly. The document itself says to run the creation once
Role attributes	parkit_app: LOGIN only, not superuser, no CREATEDB, no CREATEROLE, SCRAM-SHA-256 password. parkit_runtime_grp: NOLOGIN
Privilege matrix (S I U D T)	parking_zone S-U, payment SI, staff_user S, transaction SIU,

	vehicle SIU. No DELETE or TRUNCATE anywhere
Sequences	No privilege on any of the 5 sequences
Schema and database	USAGE on public, no CREATE on public, CONNECT on the database. Database ACL: parkit_runtime_grp=c
Other databases	parkit_app cannot connect to the postgres database

4. Tests with a real login as parkit_app

Test	Expected	Actual
Read staff_user	Allowed (login check)	Allowed. The password hashes are readable, which the login page needs
UPDATE staff_user (promote staff to Admin)	Denied	Denied
INSERT a vehicle	Allowed	FAILED: permission denied for sequence vehicle_vehicle_id_seq
nextval on the vehicle sequence	Allowed	Denied
UPDATE or DELETE payment	Denied	Denied
DELETE transaction or vehicle	Denied	Denied
TRUNCATE payment	Denied	Denied
CREATE TABLE, DROP TABLE	Denied	Denied (no CREATE on public, not owner)
CREATE ROLE, read pg_authid	Denied	Denied
VACUUM	Denied	Skipped with a warning
CREATE TEMP TABLE	Not intended	Allowed (PUBLIC has TEMP on the database by default)

The one real failure is the sequences. Section 4.4 of the document tells the reader to inspect schema.sql and grant sequence rights if sequences exist, but the SQL it provides does not include that grant, and schema.sql defines 5 sequences (all the ids are serial). As written, the least-privilege account cannot create any record.

5. The application running as parkit_app

The app was started with config\database.php set to parkit_app. The first attempt of this part was made while the lot was still full from Activity 3, so entries were refused for that reason; capacity was freed and the part repeated (file a4_app_roles.txt).

Step	Result
Login (reads staff_user) and dashboard (reads and recounts parking_zone)	Work
Register a vehicle, with the document's grants only	FAILED. The page shows the raw database error ("SQLSTATE[42501] … permission denied for sequence vehicle_vehicle_id_seq") and no vehicle row is created
Same, after adding GRANT USAGE, SELECT ON ALL SEQUENCES to the group (our addition, roles_fix.sql)	Works. Two vehicle entries created
Payment and exit of a car parked 4 h	Works. PHP 60.00 recorded (insert payment, update transaction and zone)
Edit a vehicle	Works (UPDATE is granted)
Delete a vehicle that has no transactions	FAILED with the raw error "permission denied for table vehicle" shown on the page. The vehicle stays. The app has a Delete button and delete.php, but the document grants no DELETE, so the two disagree

6. Application roles: Administrator and Staff

user-role.md says only the Administrator registers vehicles and maintains vehicle records, and that Staff cannot. This was tested with the two default accounts.

Action	Expected for Staff	Actual (logged in as staff)
Register a vehicle entry	Denied	Allowed. STAFF-1 was registered
Edit a vehicle	Denied	Allowed. STAFF-1 was changed to Motorcycle
Open Module 1 and Module 2	Module 2 allowed	Both open
Take a payment and exit a vehicle	Allowed	Allowed (PHP 30.00)

The cause is in the code. isAdmin() is defined in includes/functions.php but is never called by any page. The role is stored in the session and only displayed as a badge in the header. requireLogin() is the only check, so Administrator and Staff have the same rights.

7. Other access checks

Check	Result
Pages without login	All redirect to the login page, the JSON endpoint answers 401
Use of the old cookie after logout	Redirected to the login page (HTTP 302), so logout works
Form post from another site (Origin: http://evil.example) with a valid session and no token	Accepted. Vehicle CSRF-1 was registered
Six wrong passwords in a row, then the right one	All six answered "Invalid username or password" and the right one then logged in. No lockout or delay
SQL text as the username	Rejected as invalid, no error details
Passwords at rest	bcrypt hashes. Default passwords admin123 and staff123 are written in config/seed.php and in the README
Database credentials	config\database.php in the repository uses the postgres superuser with a fixed password
pg_hba.conf	scram-sha-256 on every rule (local, 127.0.0.1, ::1), no trust entries

8. Issues and recommendations

#	Finding	Recommendation
1	Administrator and Staff have identical rights in the app. isAdmin() is never used, so Staff can register and edit vehicles, against the project's own document	Call isAdmin() on vehicle registration, edit and delete, and on the matching forms
2	The document's database script does not grant sequence privileges, so parkit_app cannot insert anything	Add GRANT USAGE, SELECT ON ALL SEQUENCES IN SCHEMA public TO parkit_runtime_grp, and put the whole script in a .sql file
3	The app is configured for postgres, and the least-privilege account is only described in a document	Make parkit_app the default in config\database.php and read the password from an environment variable
4	The delete function conflicts with the grants (no DELETE for parkit_app)	Decide one way: remove delete from the app, or grant DELETE on vehicle only
5	Permission errors are shown to the user as raw SQLSTATE messages	Log the error and show a short message
6	No CSRF protection, no lockout on repeated wrong passwords, default	Add a CSRF token, rate-limit the login, and change the passwords on first login

	passwords known	
7	seed.php is open to anyone (Activity 3)	Remove or protect it after setup
8	The role SQL is not repeatable	Wrap CREATE ROLE in a DO block that checks pg_roles

9. Feedback for the owners

Findings 1 and 2 matter most. The database part of the design (a group role, a dedicated login account, no DELETE on payments or transactions) is a good least-privilege layout and everything in it worked except the missing sequence grant.

10. Limitations

parkit_runtime_grp and parkit_app did not exist before the test, so their start state was clean. The sequence grant used in section 5 is our addition, not part of the project. The first run of the application part was invalid because the lot was full and was repeated.

AI usage declaration

- Tool: Claude (Anthropic).
- Tasks: interpreting the results of the testing.
- Validation: the commands were run by the group on its own computer, and every result in this report comes from the saved output files.